Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Introducción a la Seguridad en el Software y DevSecOps

Ing. Roxana Quiroga Sollinger



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

1.1 El software funciona, pero ¿es seguro?

1.2 ¿Por qué falla el software?

1.3 El costo real de la inseguridad

1.4 El SDLC tradicional y la seguridad tardía

1.5 De Agile a DevOps

1.6 DevSecOps: integrar seguridad

1.7 **CAMS: Culture y Automation**

1.8 **CAMS: Mesurement y Sharing**

1.9 La seguridad como proceso continuo



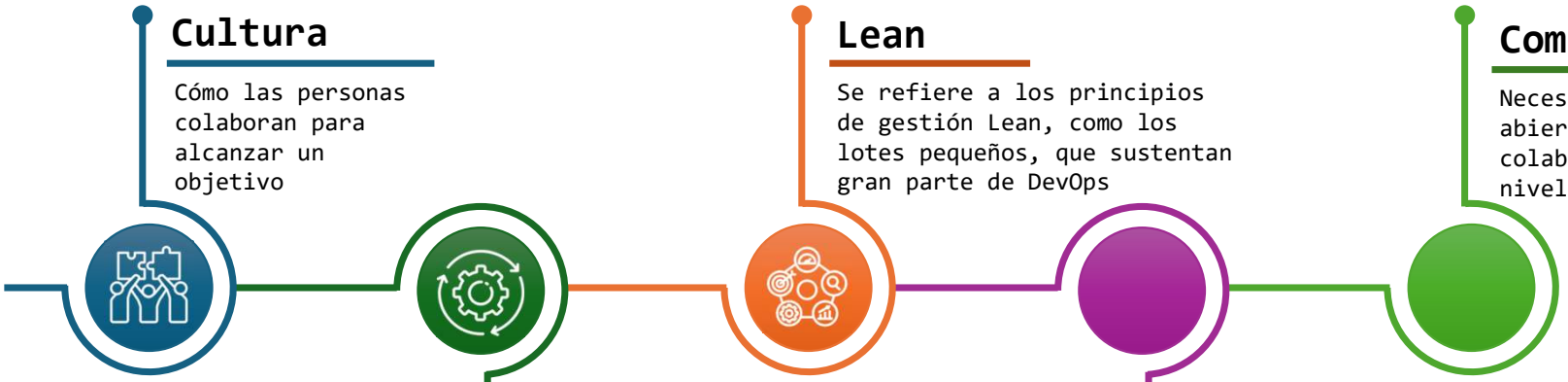
1.7 y 1.8 CAMS

- CALMS Framework
- Organizando la Cultura para DevSecOps
- Automatización en DevSecOps
- Métricas para DevSecOps
- La responsabilidad compartida



1.7 y 1.8 CAMS

CALMS Framework



FADENA

1.7 y 1.8 CAMS

Organizando la Cultura para DevSecOps

Cultura como Fundamento

Si la colaboración no forma parte de los valores compartidos y de la cultura de la empresa, ningún cambio en la estructura organizativa resolverá la falta de alineación.

De hecho, las empresas sin una cultura colaborativa raramente adoptan estructuras alternativas con éxito.



Estructura como Facilitador

No existe una única forma correcta de organizarse. Lo primordial es que la estructura elegida reduzca las transferencias de responsabilidad (hand-offs) y fomente la autonomía.

Aprender de la madurez lograda en DevOps es el mejor punto de partida para DevSecOps.



Security Champion

FADENA

1.7 y 1.8 CAMS

Automatización en DevSecOps



Colaboración

Se debe buscar herramientas que faciliten una mejor colaboración entre equipos.

Flujo de valor

Herramientas de CI/CD, como Jenkins y CircleCI, son clave para el Primer Método de DevOps.

Empoderamiento

Se otorga a los ingenieros mayor control sobre el ciclo de vida de la aplicación.

Retroalimentación

La entrega en lotes pequeños, habilitada por las herramientas de CI/CD, permite una retroalimentación rápida de los clientes, lo que permite observar rápidamente el impacto que sus cambios tienen en ellos.

Shift Left

Utilizar el desarrollo guiado por pruebas e incorporar pruebas de seguridad en el proceso puede aumentar la calidad del servicio y brindar mayor confianza.

1.7 y 1.8 CAMS

Métricas para DevSecOps

Métricas Oerativas

Estas son métricas clave que debes revisar a diario, semanalmente y mensualmente para determinar si tu práctica de DevSecOps está dando los resultados esperados. Al desarrollar las métricas operacionales, se ddebe considerar cuidadosamente la periodicidad de las mismas. Diferentes métricas pueden ser más relevantes y aportar más valor en diferentes periodos de tiempo. Algunas métricas deben revisarse diariamente, mientras que otras serán más útiles para analizar tendencias semanal o mensualmente.

Métricas directivas

El objetivo es informar sobre la efectividad del programa DevSecOps a los altos ejecutivos y a la junta directiva.
Al considerar las métricas a nivel de junta directiva, debe tener en cuenta qué es lo que la junta realmente quiere saber. El consejo querrá saber si la empresa está protegida o, más concretamente, si el riesgo residual, si cumple con la tolerancia al riesgo de la empresa. Además, querrá asegurarse de que la inversión que la empresa realiza en mitigación de riesgos genere el mayor valor posible.

Midiendo la Transformaciòn

- Velocidad: mide la cantidad de elementos completados en un período de tiempo definido.
- Tiempo de entrega: mide el tiempo desde la creación de la idea hasta la entrega al cliente.Iincluye el tiempo en la lista de tareas pendientes.
- Exposición al riesgo por función NIST: mide el nivel de riesgo para cada una de las funciones definidas por NIST
- Tiempo medio de resolución (MTTR): Este es el tiempo que transcurre desde que comienza un incidente hasta que se resuelve por completo.

1.7 y 1.8 CAMS

La responsabilidad compartida

Responsabilidad en el Origen



En DevSecOps, la seguridad no se puede transferir a un equipo externo al final del ciclo. Cada rol asume la protección de su entregable:
Desarrollo, Rdes y Herramientas

Riesgo de la Dispersión



Afirmar vagamente que "ahora todos son responsables" suele traducirse en que nadie asume la responsabilidad real.

Responsible

Quien realiza el trabajo práctico para completar la tarea.

Accountable

Único responsable final de asegurar el éxito de la tarea

Consulted

Expertos cuyo criterio e insumos son requeridos



Informed

Personas mantenidas al tanto del progreso y avances y desafíos.